

GRC PORTFOLIO PROJECT

Security Awareness Training Policy

Bright Smile Family Dentistry — Mock Organization

EFFECTIVE DATE	PREPARED BY	VERSION
May 2026	Melissa Gaither, CompTIA Security+	1.0
REVIEW CYCLE	FRAMEWORK	
Annual	HIPAA Security Rule §164.308(a)(5)	

TABLE OF CONTENTS

- 1. Purpose
- 2. Scope
- 3. Policy Statement
- 4. Training Requirements
- 5. Required Training Topics
- 6. Training Delivery Methods
- 7. Documentation and Recordkeeping
- 8. Enforcement and Disciplinary Action
- 9. Roles and Responsibilities
- 10. Policy Review and Maintenance
- 11. Training Completion Log

12. Employee Acknowledgment Form

POLICY NUMBER

BSFD-SEC-001

EFFECTIVE DATE

May 2026

REPLACES

N/A — Initial Version

POLICY OWNER

Security Officer / Office Manager

NEXT REVIEW DATE

May 2027

APPROVED BY

Practice Owner / Lead Dentist

1 Purpose

The purpose of this policy is to ensure that all workforce members at Bright Smile Family Dentistry receive regular, documented security awareness training that equips them to recognize, avoid, and report cybersecurity threats that could compromise electronic Protected Health Information (ePHI).

Human error is the leading cause of healthcare data breaches. Phishing emails, weak passwords, and unattended workstations are not IT problems — they are people problems that training can prevent. This policy establishes the minimum standards for security awareness training across the entire practice.

Regulatory Basis

The HIPAA Security Rule requires covered entities to implement a security awareness and training program for all workforce members, including management (45 CFR §164.308(a)(5)). Failure to provide documented training is one of the most commonly cited HIPAA violations during OCR audits.

2 Scope

This policy applies to **all workforce members** of Bright Smile Family Dentistry without exception, including:

- Full-time and part-time employees
- Temporary and contract staff
- Volunteers with access to practice systems
- Dentists, hygienists, and clinical staff
- Administrative and front desk personnel
- Management and practice owners
- New hires — training must be completed **before** accessing any practice systems or ePHI

Why Everyone — Including Dentists?

HIPAA defines "workforce" as all employees regardless of role or seniority. A dentist who clicks a phishing link or leaves a workstation unlocked creates the same compliance exposure as any other staff member. No role is exempt.

3 Policy Statement

Bright Smile Family Dentistry is committed to protecting the privacy, security, and integrity of patient information. All workforce members share responsibility for maintaining a secure environment. Security awareness training is not optional — it is a condition of employment and a legal requirement under HIPAA.

The practice will provide training that is relevant, practical, and specific to the threats faced by a dental healthcare environment. Training will be updated regularly to reflect the evolving threat landscape, as cyberattack techniques change and improve on a daily basis.

4 Training Requirements

Training Type	Who	When	Frequency
Initial / Onboarding Training	All new hires	Before accessing any practice system or ePHI	Once at hire
Annual Refresher Training	All workforce members	Within the same calendar month each year	Annually
Post-Incident Training	Affected staff or all staff depending on incident type	Within 30 days of a security incident	As needed
Policy Change Training	All workforce members	Within 60 days of a significant policy or regulatory change	As needed
Role-Specific Training	Staff with elevated system access	Upon role change or promotion	As needed

5 Required Training Topics

All annual and onboarding training must cover the following topics at minimum. Topics may be expanded but not reduced without Security Officer approval.

TOPIC 01

Phishing Awareness

Recognizing fraudulent emails designed to steal credentials or install malware. How

TOPIC 02

Vishing Awareness

Recognizing fraudulent phone calls from attackers posing as vendors, IT support,

to identify suspicious links, spoofed sender addresses, and urgent language designed to cause panic. What to do — and not do — when a phishing email arrives.

insurance companies, or other trusted parties. Never provide passwords, system access, or patient information over the phone without verifying the caller's identity through official channels.

TOPIC 03

Physical Security & Tailgating

Preventing unauthorized individuals from following staff into restricted areas of the practice. All visitors must be escorted. Staff are empowered to politely challenge anyone they do not recognize in non-public areas of the office.

TOPIC 04

Clean Desk & Clean Screen

Patient schedules, records, and personal information must never be visible to other patients or unauthorized individuals. Computer screens at the front desk must be positioned or filtered to prevent patient information from being seen from the waiting area.

TOPIC 05

Document Disposal & Shredding

Any document containing patient information — including printed schedules, routing slips, and insurance forms — must be shredded using a cross-cut shredder. Documents must never be placed in regular trash or recycling bins. Shredding bins must be emptied regularly by the authorized shredding vendor.

TOPIC 06

Password Security

Creating strong passwords of at least 12 characters combining letters, numbers, and symbols. Passwords must never be shared with coworkers, written on sticky notes, or reused across multiple systems. Each staff member is responsible for their own login credentials.

TOPIC 07

Workstation Locking & Logoff

Staff must lock their workstation or log out whenever stepping away — even briefly. A patient's information must never be left visible on screen when moving to a different patient or leaving the work area. Computers must be fully logged off at the end of each shift.

TOPIC 08

Incident Recognition & Reporting

Recognizing warning signs of a security incident including unusual pop-ups, computers that won't respond, unexpected password prompts, or suspicious emails. Staff must report anything unusual to the Office Manager immediately — never attempt to investigate or fix it independently.

TOPIC 09

Malware & Ransomware

Awareness

Understanding what ransomware is, how it spreads, and what it looks like when it strikes. The single most important rule: do not click anything on an affected computer. Disconnect from the network and notify the Office Manager immediately. Paying a ransom does not guarantee data recovery and does not eliminate HIPAA notification obligations.

6 Training Delivery Methods

Training may be delivered through any of the following methods, provided that completion can be documented and verified:

Method	Description	Best Used For
In-Person Group Training	Instructor-led session with all staff present	Annual refresher, post-incident training
Online Training Platform	Self-paced modules with quiz completion tracking (e.g., KnowBe4, Proofpoint)	Onboarding, annual refresher
Simulated Phishing Exercise	Practice sends a fake phishing email to test staff recognition and response	Ongoing awareness reinforcement
Written Materials + Acknowledgment	Policy documents distributed with signed acknowledgment of receipt	Policy updates, supplemental training

Recommended Best Practice

Combine at least two methods annually — for example, an online training module followed by a simulated phishing exercise 30 days later. This reinforces learning and provides measurable data on staff awareness levels.

HIPAA requires that training be documented. If an OCR audit occurs, the practice must be able to produce records proving that every workforce member completed training. The rule is simple: **if it isn't documented, it didn't happen.**

REQUIRED DOCUMENTATION FOR EVERY TRAINING SESSION

- Date training was conducted
- Topics covered and training materials used
- Name of trainer or training platform
- Full name of each participant
- Participant signature or electronic acknowledgment confirming completion
- Security Officer or Office Manager signature

RECORDKEEPING REQUIREMENTS

- Training records must be retained for a minimum of **6 years** per HIPAA documentation requirements
- Records must be stored securely — either in a locked physical file or a secured digital system
- Records must be accessible to the Security Officer and Practice Owner at any time
- A Training Completion Log (see Section 11) must be maintained and updated after every training session

8 Enforcement and Disciplinary Action

Completion of security awareness training is a condition of employment. Failure to complete required training within the designated timeframe will result in progressive disciplinary action as outlined below. All disciplinary actions must be documented.

1 **First: Reminder and Final Deadline**

Office Manager issues a written reminder with a firm completion deadline of 5 business days. System access may be temporarily restricted until training is completed.

2 **Second: Formal Written Warning**

A formal written warning is issued and placed in the employee's personnel file. The warning documents the policy violation and states that further non-compliance may result in termination.

3 **Third: Disciplinary Action Up To and Including Termination**

Continued non-compliance places the practice at direct HIPAA liability and demonstrates a disregard for patient privacy. Termination may be pursued at the Practice Owner's discretion. All steps must be documented prior to termination.

Zero Tolerance: Intentional Policy Violations

Any workforce member who intentionally circumvents security controls, shares passwords, or deliberately ignores a known security threat may be subject to immediate termination and referral to appropriate authorities, bypassing the progressive discipline process.

9 Roles and Responsibilities

Role	Responsibilities
Security Officer	Develops and maintains this policy; coordinates training content and scheduling; maintains training records; monitors compliance; updates training after incidents or regulatory changes
Office Manager	Ensures all staff complete training within required timeframes; issues reminders and disciplinary notices; maintains physical training records; conducts onboarding training for new hires
Practice Owner / Lead Dentist	Approves this policy annually; sets the tone from the top by completing training themselves; authorizes disciplinary action when required
IT MSP	Supports delivery of technical training topics; administers simulated phishing exercises; provides training data and completion metrics from any online platforms used
All Workforce Members	Complete all required training on time; apply training to daily work practices; report suspicious activity immediately; sign acknowledgment forms confirming completion

10 Policy Review and Maintenance

Activity	Frequency	Owner
Full policy review and update	Annual	Security Officer
Training content review and refresh	Annual	Security Officer + IT MSP
Review after any security incident	Within 30 days of incident	Security Officer
Review after HIPAA regulatory changes	Within 60 days of change	Security Officer
Simulated phishing exercise	Semi-Annual	IT MSP
Training completion audit	Annual	Office Manager

11 **Training Completion Log**

This log must be completed after every training session and retained for a minimum of 6 years.

Employee Name	Role	Training Type	Date Completed	Topics Covered	Employee Signature	Verified By

12 **Employee Acknowledgment Form**

This form must be signed by each workforce member upon completion of training and retained in their personnel file.

I, the undersigned, acknowledge that I have completed the Bright Smile Family Dentistry Security Awareness Training and have received, read, and understood the following:

- The importance of protecting electronic Protected Health Information (ePHI)
- How to recognize and respond to phishing and vishing attempts
- Physical security practices including tailgating prevention and clean desk requirements
- Proper document disposal and shredding procedures

- Password security requirements and workstation locking procedures
- How to recognize and report a security incident
- Malware and ransomware awareness and response

I understand that compliance with this policy is a condition of my employment, and that failure to comply may result in disciplinary action up to and including termination.

Employee Full Name (Print)

Employee Signature

Date

Job Title / Role

Training Date

Verified By (Security Officer / Office Manager)

Portfolio Note: This is a mock Security Awareness Training Policy created as a cybersecurity career portfolio project. Bright Smile Family Dentistry is a fictional organization. All requirements are based on real HIPAA Security Rule standards (45 CFR §164.308(a)(5)) and industry best practices.

REFERENCES

- HIPAA Security Rule — 45 CFR §164.308(a)(5) — Security Awareness and Training.

<https://www.hhs.gov/hipaa/for-professionals/security/index.html>

- HHS Office for Civil Rights — HIPAA Security Rule Guidance.
<https://www.hhs.gov/hipaa/for-professionals/security/guidance/index.html>
- NIST SP 800-50 — Building an Information Technology Security Awareness and Training Program. <https://csrc.nist.gov/publications/detail/sp/800-50/final>
- CompTIA Security+ Study Guide, Exam SY0-701

Prepared by: **Melissa Gaither** | CompTIA Security+ | GitHub: CyberMomma-3

This document is part of a cybersecurity career transition portfolio.